# CORTAFUEGOS

## EN AUDITORÍAS DE SEGURIDAD

- Principios generales
- Componentes de un cortafuegos de red
- Tipos por ubicacion y funcionalidad
- Arquitecturas de cortafuegos
- Arquitecturas avanzadas

CONTENIDOS

# UD5


**01** **Principios generales de cortafuegos**

Definicion, objetivos, normativa y principio de minimo privilegio

**02** **Componentes de un cortafuegos de red**

Packet filter, proxy, NAT, VPN, IDS/IPS integrado

**03** **Tipos por ubicacion y funcionalidad**

Perimetral, interno, DMZ, personal, NGFW, WAF, cloud

**04** **Arquitecturas de cortafuegos de red**

Screened host, dual-homed, DMZ clasica, screened subnet

**05** **Otras arquitecturas avanzadas**

Defense in depth, NGFW, SD-WAN, Zero Trust, cortafuegos en nube

SECCIÓN

# 01

## Principios Generales de Cortafuegos

# PRINCIPIOS GENERALES · Definición y Objetivos

## ¿QUÉ ES UN CORTAFUEGOS?

Sistema o conjunto de sistemas que controla el flujo de tráfico entre redes con distinto nivel de confianza, aplicando una política de seguridad definida por el administrador.

### Marco normativo

- RFC 2979 — Comportamiento de cortafuegos e impacto en aplicaciones
- ENS (RD 311/2022) — op.exp.1, mp.com.1
- ISO 27001:2022 — A.8.20, A.8.22
- NIST SP 800-41 — Guidelines on Firewalls

### Control de acceso

Permite o deniega tráfico según política

### Visibilidad

Registra y audita el tráfico de red

### Confidencialidad

Impide acceso no autorizado a recursos internos

### Segmentación

Aísla zonas de red con distinto nivel de riesgo

# PRINCIPIOS GENERALES · Principios de Funcionamiento

## Default Deny

Todo el tráfico se deniega por defecto. Solo se permite lo explícitamente autorizado. Implementación: política DROP en iptables/nftables.

## Mínimo Privilegio

Cada zona o usuario recibe solo los accesos estrictamente necesarios para su función. Reduce la superficie de ataque.

## Defensa en Profundidad

Un único cortafuegos nunca es suficiente. Se combinan múltiples capas (perimetral + interno + WAF + NGFW) para compensar fallos.

## Separación de Zonas

Las redes se segmentan en zonas de confianza diferenciada: Internet (0), DMZ (5), LAN (10). El tráfico entre zonas se filtra explícitamente.

**PRINCIPIO RECTOR**

*"Todo lo que no está expresamente permitido, está prohibido"*

**Whitelist vs. Blacklist**

Whitelist: más seguro, más restrictivo
Blacklist: más permisivo, difícil de mantener

SECCIÓN

# 02

## Componentes de un Cortafuegos de Red

# COMPONENTES · Módulos Funcionales

### Packet Filter

Inspecciona cabeceras IP/TCP/UDP. Filtra por IP src/dst, puerto, protocolo y flags TCP. Stateless → no recuerda conexiones previas.

### Stateful Inspection

Mantiene una tabla de estado de conexiones activas. Permite el tráfico de retorno solo para conexiones iniciadas desde dentro. RFC 3234.

### Application Proxy

Intermediario a nivel de aplicación (L7). Rompe la conexión TCP. Puede inspeccionar el contenido (payload) de cada protocolo.

### NAT / PAT

Network Address Translation. Oculta las IPs internas de la red. PAT (Port Address Translation) permite múltiples hosts con una sola IP pública.

### IDS/IPS integrado

Intrusion Detection/Prevention. El IDS detecta y alerta; el IPS bloquea activamente. Firmas + análisis de anomalías de comportamiento.

### VPN Gateway

Cifra el tráfico entre sedes o teletrabajadores (IPsec, SSL/TLS). El cortafuegos termina los túneles VPN y aplica política al tráfico descifrado.

# COMPONENTES · Nivel de Inspección por Capa OSI

| | CORTAFUEGOS / TECNOLOGÍA | PROTOCOLOS / EJEMPLOS |
|---|---|---|
| L7 App | Proxy, WAF, NGFW | HTTP, FTP, DNS, SMTP |
| L6 Present | Proxy SSL / DPI | TLS, cifrado |
| L5 Sesion | Stateful inspection | Gestión de sesiones |
| L4 Transporte | Stateful, Packet filter | TCP/UDP, puertos |
| L3 Red | Packet filter, ACL | IP, ICMP, routing |
| L2 Enlace | MAC filtering (switches) | Ethernet, VLANs |

SECCIÓN

# 03

## Tipos de Cortafuegos por Ubicación y Funcionalidad

# TIPOS · Por Ubicación en la Red

## Cortafuegos Perimetral

El guardián del borde de red

Situado entre Internet y la red interna. Primera línea de defensa. Filtra todo el tráfico entrante y saliente. Implementa la política de seguridad de la organización frente al exterior.

- Frontera Internet/LAN
- NAT/PAT hacia exterior
- IP pública en WAN

## Cortafuegos Interno

Segmentación dentro de la LAN

Separa segmentos internos con distintos niveles de confianza: usuarios vs. servidores, departamentos, sistemas SCADA. Contiene la propagación lateral de amenazas (lateral movement).

- Inter-VLAN filtering
- Micro-segmentación
- Contención de brechas

## Cortafuegos Personal

Protección del endpoint

Software instalado en el propio dispositivo (Windows Defender Firewall, iptables en Linux). Controla el tráfico de red de una sola máquina. Complementa la seguridad de red.

- Windows Defender FW
- iptables / nftables
- Último nivel de defensa

# TIPOS · Por Funcionalidad Tecnológica

## Packet Filter (Generación 1)

1988

Solo cabeceras IP/TCP. Stateless. ACLs en routers. Rápido pero evadible con IP spoofing.

## Stateful Inspection (Gen. 2)

1992

Tabla de estado de conexiones. Permite solo tráfico de retorno legítimo. El estándar actual en FWs de red.

## Application Proxy (Gen. 3)

1994

Inspecciona el payload L7. Entiende FTP, HTTP, DNS. Rompe la conexión TCP. Más lento pero más seguro.

## NGFW (Next-Gen, Gen. 4)

2004+

DPI + IPS + SSL inspection + identificación de aplicaciones (App-ID) + control por usuario. Palo Alto, Fortinet, Check Point.

## WAF (Web App FW)

2000+

Protección L7 específica para HTTP/HTTPS. OWASP Top 10, mod_security, Cloudflare WAF. Obligatorio para apps web críticas.

## Cloud FW (FWaaS)

2010+

Cortafuegos como servicio. Zscaler, AWS Network FW, Azure FW. Sin hardware. Escalado automático.

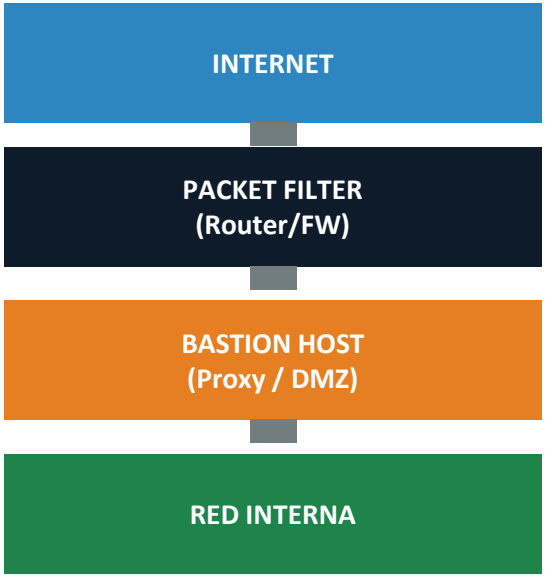
SECCIÓN

# 04

## Arquitecturas de Cortafuegos de Red

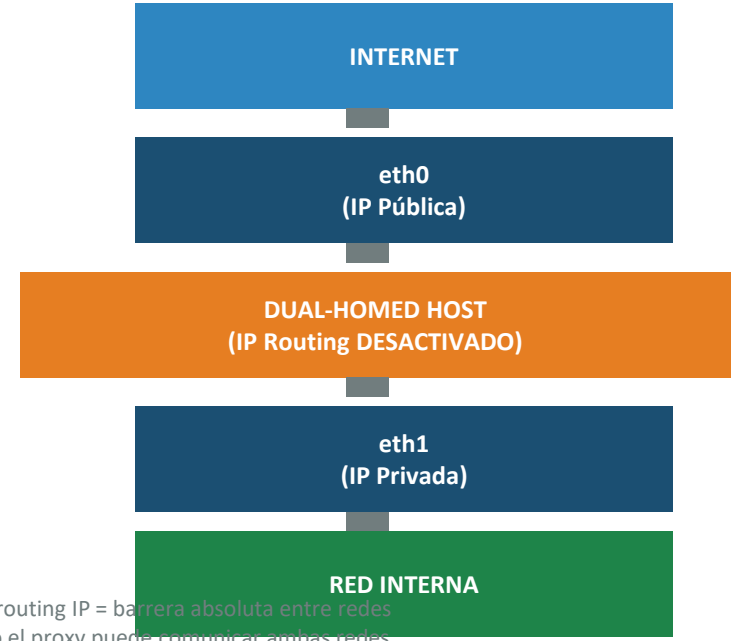
# ARQUITECTURAS · Screened Host y Dual-Homed Host

## Screened Host




+ Solo el bastion host es visible desde Internet
+ FW descarta tráfico hacia red interna
− Bastion comprometido = red interna en riesgo

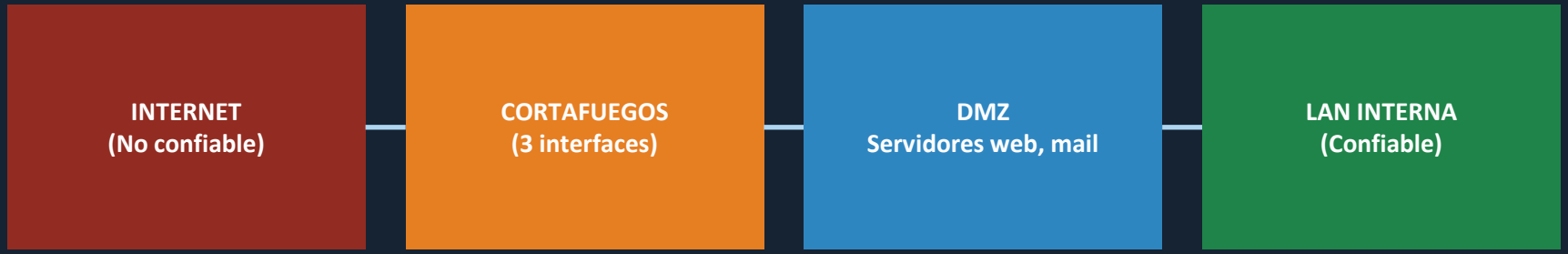
## Dual-Homed Host




+ Sin routing IP = barrera absoluta entre redes
+ Solo el proxy puede comunicar ambas redes
− Bastion es el único punto de acceso (SPOF)

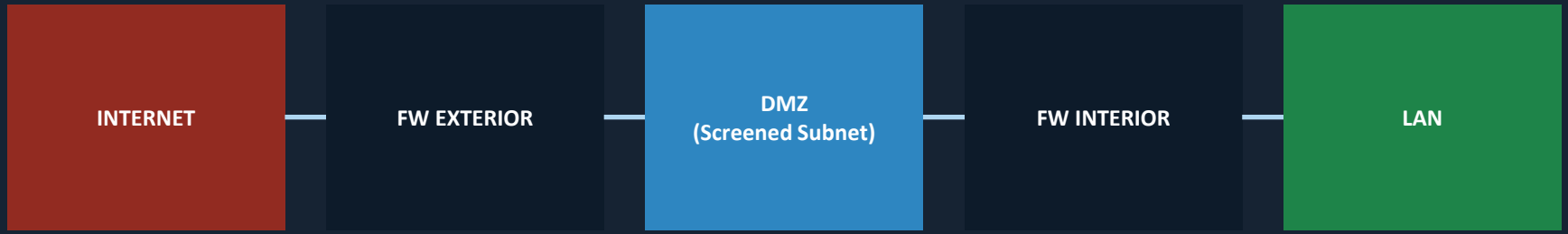
# ARQUITECTURAS · DMZ Clásica y Screened Subnet

## DMZ CLÁSICA — Un solo cortafuegos con tres interfaces




Ventaja: Bajo coste (un solo dispositivo) · Riesgo: El FW comprometido expone todo

## SCREENED SUBNET — Dos cortafuegos (exterior + interior)




Arquitectura de referencia: máxima seguridad. Un atacante debe comprometer DOS cortafuegos para llegar a la LAN.

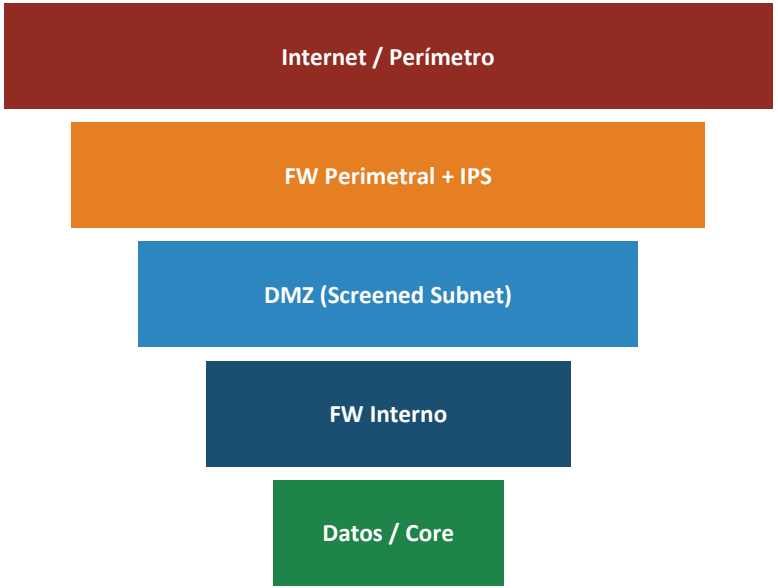
SECCIÓN

# 05

## Otras Arquitecturas de Cortafuegos

# OTRAS ARQUITECTURAS · Defense in Depth y NGFW

## Defensa en Profundidad (Defense in Depth)




Principio: ninguna capa es infalible. Si una falla, la siguiente contiene el ataque. Cada capa añade fricción al atacante.

## Next-Generation Firewall (NGFW)

**Deep Packet Inspection**
Inspección del payload completo hasta L7, incluido tráfico cifrado (SSL Inspection)

**App-ID / Application Control**
Identifica la aplicación independientemente del puerto (Skype, BitTorrent, Netflix)

**User-ID**
Políticas por usuario/grupo Active Directory, no solo por IP

**IPS integrado**
Detección y bloqueo de exploits en tiempo real con base de firmas actualizada

**SSL/TLS Inspection**
Descifra, inspecciona y re-cifra tráfico HTTPS. Requiere CA de confianza en endpoints

**Threat Intelligence**
Integración con feeds de inteligencia de amenazas (IoCs, reputación de IPs, dominios)

# OTRAS ARQUITECTURAS · Zero Trust y Cortafuegos en Nube

## Modelo Zero Trust

*"Never Trust, Always Verify"*
*— NIST SP 800-207*

- No existe el perímetro de red: el usuario puede estar en cualquier lugar
- Toda conexión se autentica, autoriza y verifica continuamente
- Mínimo privilegio: acceso solo al recurso necesario, no a toda la red
- Micro-segmentación: cada carga de trabajo aislada individualmente
- Monitorización continua: todo el tráfico se registra y analiza
- Implementación: ZTNA, SDP, Identity-Aware Proxy (Google BeyondCorp)

## Cortafuegos en la Nube (FWaaS)

| | |
|---|---|
| **FWaaS (FW as a Service)** | Zscaler, Cloudflare Gateway. El tráfico de usuario se redirige a la nube para ser inspeccionado antes de llegar al destino. |
| **Cloud-native FW** | AWS Network Firewall, Azure Firewall, GCP Cloud Armor. FW gestionado por el proveedor cloud para proteger recursos en VPCs. |
| **Virtual FW** | Instancia de FW tradicional desplegada en VM en cloud (Palo Alto VM-Series, Fortinet FortiGate-VM). Mismas funciones, sin hardware. |

Tendencia: Cortafuegos como pieza de SASE (Secure Access Service Edge)
Zscaler, Palo Alto Prisma, Cisco Umbrella, Cloudflare One

# COMPARATIVA DE ARQUITECTURAS · Criterios de Selección

| Arquitectura | Coste | Seguridad | Complejidad | Redundancia | Caso de uso | +Info |
|---|---|---|---|---|---|---|
| Packet Filter simple | Muy bajo | Baja | Baja | No | SOHO, ACLs en routers | Gen.1 |
| Screened Host | Bajo | Media | Media | Parcial | PyME sin presupuesto | Clásica |
| Dual-Homed Host | Bajo | Media-alta | Media | No | Aislamiento estricto | Clásica |
| DMZ (1 FW) | Medio | Media-alta | Media | Parcial | Empresa media | Clásica |
| Screened Subnet (2 FW) | Alto | Alta | Alta | Si | Empresa / CPD | Recom. |
| NGFW + DMZ | Muy alto | Muy alta | Alta | Si | Empresa grande | Best practice |
| Zero Trust / SASE | Variable | Máxima | Muy alta | Si | Nativo nube / teletrabajo | Futuro |

# AUDITORÍA DE CORTAFUEGOS · Qué verificar y cómo documentarlo

## ¿Qué auditar en un cortafuegos?

**Política de reglas**
¿Existe Default Deny? Reglas por servicio y IP origen/destino. Reglas redundantes o solapadas.

**Reglas ANY-ANY**
Regla 'permit any any' = no hay cortafuegos. Hallazgo crítico en cualquier auditoria.

**Servicios expuestos**
Comparar puertos abiertos (Nmap) con la política documentada. Todo lo no justificado es hallazgo.

**Logging y auditoría**
¿Se registran los deny? ¿Están los logs en un SIEM? ¿Hay alertas para intentos reiterados?

**Actualización / parches**
Versión del firmware. Vulnerabilidades conocidas (CVE). Proceso de gestión de cambios.

**Segregación de zonas**
¿Existe DMZ? ¿LAN interna separada de servidores? Verificar tráfico lateral no autorizado.

## Herramientas del auditor

```
nmap -sS/-sA/-sF/-sN   → Fingerprinting del firewall
hping3 -S/-A/-FIN      → Análisis a nivel de paquete
firewall               → TTL gateway traversal
iptables-save          → Exportar ruleset para auditoría
nmap --script firewall-bypass
```

## Controles ENS / ISO 27001 aplicables

| | |
|---|---|
| **ENS mp.com.1** | Perímetro seguro — política perimetral documentada |
| **ENS op.exp.1** | Inventario de activos (incluyendo reglas de FW) |
| **ENS op.mon.1** | Detección de intrusiones — logs de cortafuegos |
| **ISO 27001 A.8.20** | Seguridad de redes — política de gestión de red |
| **ISO 27001 A.8.22** | Segregación de redes — VLANs y DMZ documentadas |

# RESUMEN · UD5 Cortafuegos

**01**

## Principios generales

Default Deny · Mínimo Privilegio · Defensa en Profundidad · Separación de Zonas

**02**

## Componentes

Packet Filter · Stateful · Proxy · NAT · IDS/IPS · VPN → Capas OSI L3-L7

**03**

## Tipos por funcionalidad

Perimetral · Interno · Personal · NGFW · WAF · FWaaS · Cloud-native

**04**

## Arquitecturas clásicas

Screened Host → Dual-Homed → DMZ (1 FW) → Screened Subnet (2 FW, recomendada)

**05**

## Arquitecturas avanzadas

Defense in Depth · NGFW con SSL Inspection · Zero Trust (NIST 800-207) · SASE